

VIT®

Vellore Institute of Technology

(Deemed to be University under section 3 of UGC Act, 1956)

School Of Computer Science and Engineering

Technical Answers for Real World Problems (TARP)

Course Code – CSI3901

Fall Semester 2026-27

Project Report

Batch – 4

Submitted By

Akaash M K 23MIC0012

Deepsikha K V 23MIC0021

FDO-Guard: An Explainable AI Framework for Functional Data Overreach Detection in Privacy Policies

Abstract :

Mobile and web applications have successfully generated large amounts of user personal data, which is revealed, in large part, through natural-language privacy policies. These policies are often lengthy, are inconsistent in wording and are not easily understandable for the users. However, their unstructured nature also means that they are hard to represent, compare and automatically reason about using machines because related facts about a single data type may be distributed across multiple sections of a policy. This limitation weakens the automation of analysis on whether the use of data in an application is consistent with its intended use. In order to cope with this, it is proposed that privacy information be represented as structured, machine-readable knowledge using a Functional Data Ontology (FDO). Natural-language privacy policies are processed with NLP-based extraction to identify data categories, collection purposes, data processing, recipients, and retention information and translated to formal ontological relationships that link applications, functions, and data. A structured representation is stored in a knowledge graph and retrieved by means of the SPARQL query language, while a reasoning component allows for reasoning about the relationships that are not explicitly mentioned in a specific policy sentence, but are logically implied by the facts. The information is also presented in an intelligible format for users, to facilitate their understanding of declared data practices. This semantic foundation is then used to allow a comparison between the data access that an application declares and the data that the application is likely to access for its perceived core functionality. Data types that go beyond this functional expectation are recognized as examples of Functional Data Overreach, which is evaluated based on the stated purpose, justification, and disclosure, as opposed to a two-way, cut-and-dried analysis. Each detection is tracked back to evidence and reasoning that underpins that policy, allowing it to be explainable and interpretable by the user. The approach works well in all kinds of application domains, with different functional needs and data-access models, including financial services, navigation, communication, and social media. The framework is designed to take privacy-policy analysis beyond text simplification and to the automatic and explainable identification of functional data overreach using a combination of ontology-driven semantic representation with functional reasoning.

Literature Survey

S. No.	Title	Year	Author(s)	Techniques Used	Pros	Cons
1	POLIGRAPH: Automated Privacy Policy Analysis Using Knowledge Graphs	2023	H. Cui et al.	NLP, Knowledge Graphs, RoBERTa, NER, dependency parsing, coreference resolution, Sentence-BERT	This application has been designed in the way that it will gather related information from different policy paragraphs and it is quite efficient. Users get almost 97% accuracy in recalling details with this tool and also get the facility of contradiction analysis. Memory retrieval rate gets more than double from 30% to 70% when this tool is used.	Giving wrong graph edges can easily lead to propagation of errors; inability to correctly handle tables and lists; and missing some statements as well as the nuanced meanings of the language.
2	PolicyLint: Investigating Internal Privacy Policy Contradictions on Google Play	2019	Benjamin Andow et al.	NLP, NER, dependency parsing, data/entity ontologies, Hearst patterns, DED trees, negation detection, heuristic contradiction analysis	Deals with both negation and semantic hierarchies; creates ontologies by itself; policy analysis can be handled on the large scale; it is possible to find various contradiction types at the same time.	The system needs human confirmation; Natural language processing may cause misinterpretation; it is limited by the extent of ontology coverage; The system has limited ability to understand context.
3	Actions Speak Louder than Words: Entity-Sensitive Privacy Policy and Data Flow Analysis with POLICHECK	2020	Benjamin Andow et al.	Dynamic analysis, NLP, PolicyLint, AppCensus, entity/data-type ontologies, semantic reasoning	By concentrating on entities, the analysis becomes more accurate; detects disclosure of vague, omitted, incorrect, ambiguity;	Dynamic analysis may not catch all the flows; entity-mapping is not a complete set; few data types considered;

4	WHYPER: Towards Automating Risk Assessment of Mobile Applications	2013	Rahul Pandita et al.	NLP, POS tagging, phrase parsing, NER, Stanford dependencies, First-Order Logic, FSM, WordNet	Connects permissions to app descriptions using Semantically links; reduces false positives caused by the keyword method; creates permission semantic graphs without manual work.	The quality of the parser strongly influences the results; the produced semantic graphs may be incomplete; the work is restricted to three permissions only; it is not able to spot the deceptive descriptions.
5	AutoCog: Measuring the Description-to-Permission Fidelity in Android Applications	2014	Zhengyang Qu et al.	NLP, Stanford Parser, Explicit Semantic Analysis (ESA), machine learning, description-to-permission relatedness model, semantic similarity	It learns semantic patterns from the text only without relying on APIs; it was able to reach 92.6% precision and 92.0% recall; it is capable to extend the results to different permissions; 45, 811 apps were under the analysis.	The results strongly depend on the NLP parser used; if permissions are rare the training dataset is insufficient; rare semantic patterns may be missed out; there might be a few false positive detections.
6	Android Permissions Demystified	2011	Adrienne Porter Felt, Erika Chin, Steve Hanna, Dawn Song, David Wagner	Stowaway, static analysis, automated API testing, permission mapping, Randoop, DEX analysis, Java reflection analysis, ComDroid	Finds permission-privileged Android apps; creates the permission map; there is coverage of 85% of APIs;	Pure Java methods and methods from reflection/natives are very difficult to find; if permission maps are incomplete, the false positives will increase; the dead code may influence the results; sometimes the verification has to be done manually.
7	TKPERM: Cross-platform Permission Knowledge Transfer to Detect Overprivileged Third-party Applications	2020	Faysal Hossain Shezan, Kaiming Cheng, Zhen Zhang, Yinzhi Cao, Yuan Tian	Transfer learning, word embeddings, FCNN, CBOW, source-domain selection, fine-tuning, NLP-based classification	The permission knowledge can be transferred to different devices running the OS; reduces the labelling of the target domain; average F1 is 90.02%; there was a reduction in annotation efforts.	The labeling of the target data has to be quite a bit; domains that are quite different from the source will have to be discarded; different permission frameworks between source and target will make knowledge transfer hard.
8	Harnessing Language	2025	Yunik Tamrakar,	LLMs, GPT-4o, GPT-4o-mini,	GPT-4o brings a major improvement to the	It's only Android-related stuff; the generalization

	Models to Analyze Android App Permission Fidelity		Ritwik Banerjee, Ethan Myers, Lorenzo De Carli, Indrakshi Ray	BERT, BART-Large-MNLI, zero-shot inference, fine-tuning, paraphrase augmentation, multi-label classification	permission prediction; it's possible to get a 18% improvement in F1; PR-AUC is getting more stable when the paraphrasing is used; it is also working good with only a few annotated data.	part is still uncertain; very few permissions would be heavily under-represented; the labels are quite dirty; GPT-4o needs a lot of computing power
9	Operationalizing the Legal Principle of Data Minimization for Personalization	2020	Asia J. Biega, Peter Potash, Hal Daumé III, Fernando Diaz, Michèle Finck	GDPR data minimization, global/per-user minimization, kNN, FunkSVD, data-selection strategies, RMSE, NDCG, OLS regression	Presents the idea of data minimization with an emphasis on computation; less user data is actually necessary;	Quality may be lost with individual use cases; marginalized user groups might be disproportionately affected; it can vary depending on the system and background data; it is difficult to understand the meaning of privacy law from a legal point of view.
10	A Systematic Review of Privacy Policy Literature	2024	Yousra Javed, Ayesha Sajid	Systematic Literature Review, PRISMA, bibliographic analysis, ML/NLP, readability analysis, compliance analysis, user studies	Covers 202 scientific articles that have gone through peer review; it finds trends in research as well as topics that remain unexplored for now; explains both the automated and the user-directed approach to privacy-policy analysis.	It is up to the end of 2023 as far the literatures included in the review are concerned; it might lose studies if keywords are used for the search; the complete texts of some papers are simply missing; therefore, the quality of a study is one of the major things when it comes to the analysis of the included-studies.
11	A Systematic Mapping Study on Automated Analysis of Privacy Policies	2022	Jose M. Del Alamo, Danny S. Guaman, Boni García, Ana Diez	Systematic mapping, NLP, symbolic/statistical NLP, ML, ANN/deep learning, NER, classification, clustering, BERT, CNN, RNN, SVM, RF, LDA	Gives an overall automated privacy-policy analysis and Covers the results of a comprehensive comparison of 39 research papers; the work includes a comparative analysis of NLP/ML techniques; the research points out some	The existing methodologies generally fail to grasp the nuances of the context; a lot of them just detect whether the content is or is not present; the multilingual analysis and NER could use some improvements; labeled data sets are costly

					of the areas where further study is needed	
12	LADFA: A Framework of Using Large Language Models and Retrieval-Augmented Generation for Personal Data Flow Analysis in Privacy Policies	2025	Haiyue Yuan, Nikolay Matyunin, Ali Raza, Shujun Li	LLMs, RAG, prompt chaining, LLM agents, knowledge base, semantic retrieval, data-flow extraction, data-flow graphs, graph analysis	The whole process from start to finish of data-flow analysis through automation; the details about the data, sender, recipient, purpose and processing method are being extracted automatically; RAG decreases hallucination risk; graphs can help in visualizing the data	Hallucinations of LLMs may impact the reliability of your results; the term usage varies quite a bit; tested on only ten privacy policies of automotive companies; expert validation is a must
13	Explainable AI in Usable Privacy and Security: Challenges and Opportunities	2025	Vincent Freiberger, Arthur Fleig, Erik Buchmann	LLM-as-a-Judge, GPT-4o, XAI, Human-Centered XAI, prompt engineering, Likert evaluation, RAG, uncertainty estimation	Enhances the LLM privacy assessment by adding another layer of transparency; facilitates explanations that are interactive/user-adaptable; counters hallucinations and calibrates trust	Some explanations might be overly general or even misleading; some logical reasoning might appear first in mind or after thinking and may not be accurate or complete; the assessment process is very subjective and depends on the reviewer; RAG results in an increase in calculation cost; personalization might pose a privacy risk
14	A Privacy Scoring Framework: Automation of Privacy Compliance and Risk Evaluation with Standard Indicators	2023	Nakyoung Kim, Hyeontaek Oh, Jun Kyun Choi	NLP, supervised ML, hierarchical binary classifiers, TF-IDF bigrams, Random Forest, SVM, Naïve Bayes, OPP-115, privacy indicators, permission analysis, user-interaction analysis	It is a combination between compliance and privacy-risk evaluation; there are common performance indicators;	It combines the policy and permissions into one; it can be applied to more than 10, 000 apps; The recall (RF) score is a very high 89.1% F1.
15	PrivComp-KG:	2024	Leon Garza,	LLMs, RAG, Knowledge	Links different privacy-policy sections to articles	Mainly targeted to General Data Protection

	Leveraging Knowledge Graph and Large Language Models for Privacy Policy Compliance Verification		Lavanya Elluri, Anantaa Kotal, Aritran Piplai, Deepti Gupta, Anupam Joshi	Graphs, RDF, OWL, SWRL, Llama 7B, ChromaDB, embeddings, semantic similarity, SPARQL, regulatory reasoning	in GDPR. Combines a large language model (LLM), retrieval augmentation generation (RAG) and knowledge graph (KG) technology to reduce hallucination, automate compliance reasoning and find missing regulatory requirements.	Regulation (GDPR). The quality of RAG largely comes down to retrieval. Quite modest OPP-115 assessment.KG and rule quality determine to a great extent the outcome of compliance checking.
16	Using LLMs for Automated Privacy Policy Analysis: Prompt Engineering, Fine-Tuning and Explainability	2025	Yuxin Chen, Peng Tang, Weidong Qiu, Shujun Li	LLMs, prompt engineering, few-shot learning, CoT, LoRA fine-tuning, hierarchical multi-label classification, Llama, Qwen, ChatGLM, OPP-115, GoPPC-150, CAPP-130, APPCP-100	The fine-tuned LLM outdoes most SOTA methods with a score of 0.916 micro-F1 on the OPP-115 dataset, it works for English and Chinese, and generates human-understandable explanations.	Prompts-only have low accuracy since the model gets wrong info; it is the fine-tuning makes a big difference. Didn't include larger models. The model can still generate explanations that are shallow in reasoning.
17	GraphCompliance: Aligning Policy and Context Graphs for LLM-Based Regulatory Compliance	2025	Jiseong Chung, Ronny Ko, Wonchul Yoo, Makoto Onizuka, Sungmok Kim, Tae-Wan Kim, Won-Yong Shin	Policy Graph, Context Graph, Compliance Gate, GraphRAG, LLMs, entity-relation triples, hypernym mapping, dense retrieval, bi-encoder/cross-encoder, reference traversal, exception handling	Merges graph structure with LLM semantic reasoning. Can process cross-references and exceptions, and also detect violated regulations or exceptions to regulations, thereby substantially reducing cases where rules were missed or incorrectly identified; significantly improves F1 compared to RAG and GraphRAG	Quality of the graph construction greatly determines outcome; primarily focused on GDPR; benchmark consists of 300 scenarios; graph construction increases complexity; there is a need for cross-regulation validation
18	Let's Measure the Elephant in the Room: Facilitating Personalized	2025	Rui Zhao, Vladyslav Melnychuk, Jun Zhao, Jesse Wright,	PoliAnalyzer, NLP, LLMs, GPT-4o/GPT-4o-mini, NER, entity/relation extraction, DPV, psDToU, Knowledge	Provides the possibility of large-scale personalized privacy-policy analysis; couples LLM extraction with symbolic reasoning; demonstrates ~90%+ F1 most of the time;	Some tasks are still complex to extract; extraction quality heavily impacts result; privacy-policy concepts covered by the formal model are not exhaustive; user

	Automated Analysis of Privacy Policies at Scale		Nigel Shadbolt	Graphs, symbolic reasoning, N3 reasoner, user-preference compliance checking	analyzed 100 websites with 23 user profiles; identifies policy segments conflicting with user preferences	preference specification is quite hard for non-experts
19	GDPR Compliance in the Context of Continuous Integration	2020	Ze Shi Li, Colin Werner, Neil Ernst, Daniela Damian	Design Science, GDPR requirement operationalization, privacy NFRs, automated GDPR testing, Python, AWS infrastructure analysis, Jenkins/CI	Converts GDPR principles into concrete testable requirements; automates repetitive compliance testing; continuously detects GDPR exposures; integrates with CI; gives exposure specifics that users can act on	Only some of the selected GDPR principles are translated into actual requirements; AWS/DataCorp-specific implementation limits the possibility for generalization; there were problems with implementation of measures detected (detected issues weren't acted on consistently by the employees); and there is still a lot of organizational effort required to achieve compliance on continuous basis
20	CompAi: A Tool for GDPR Completeness Checking of Privacy Policies using Artificial Intelligence	2024	Orlando Amaral Cejas, Sallam Abualhaija, Lionel C. Briand	Natural Language Processing (NLP), Machine Learning (ML), semantic analysis, hierarchical multi-label classification, conceptual modeling, GDPR completeness rules	Automatically compares privacy policies with GDPR requirements; finds missing or incomplete privacy info; about 96% accuracy according to tool evaluation; provides detailed reports which can be reviewed by human experts; minimizes manual compliance checking labour	Some aspects of completeness need manual input; the results are contingent on NLP/ML classification quality; GDPR only; there might be false positives/false negatives; human expert check is still necessary

Research Gap Analysis

Based on the existing privacy-policy analysis, knowledge-graph, compliance, and LLM-based approaches, we find the following key research gaps:

1. An inability to relate data to its functions. Failure to relate data to functions.

Most existing systems fail to define what data an application using them collects but lack the ability to find out why the data is practically necessary.

The use of semantic similarity between permissions and application descriptions (as in WHYPER (S4) and AutoCog (S5)) does not model the functional necessity.

Most of the existing permission-prediction approaches, including TKPERM (S7) and the LLM-based approach (S8), are still classification-based.

No explicit relationship between Application and Function and Required Data (Gap).

FDO Privacy: functional data overreach: recognises data collection without functional rationale.

2. A functional, purpose-built Privacy Ontology is lacking.There is no functional, purpose-built Privacy Ontology.

Existing KB-based approaches (such as POLIGRAPH (S1), PrivComp-KG (S15) and PoliAnalyzer (S18)) express privacy information by using generic or existing privacy vocabularies.

They don't explicitly model the functionality of the application as their own semantic layer.

No explicit model for:

Application → performsFunction → Function

Function → requiresData → DataType

DataType → usedFor → Purpose

Proposes a separate Functional Data Ontology (FDO) based on RDF/OWL.

3. The ability to detect limited functional overreach and contradiction.

The main things that are detected by PolicyLint (S2) and POLICHECK (S3) are textual contradictions, omissions, and policy–runtime inconsistencies.

Existing compliance/privacy scoring methods detect compliance problems but don't evaluate functional necessity.

Gap: There is a lack of clarity in current systems about the difference between missing disclosure and data collection that is disclosed but not necessary for functioning.

Introduces Functional Data Overreach Detection with Semantic Relationships and Reasoning (FDO Privacy).

4. Limited Explainability and Traceability

Common existing LLM-based systems deliver natural-language explanations that can be either too vague or challenging to validate.

While knowledge graphs offer some structure to relationships, graph edges do not necessarily convey "why" a collection activity is excessive.

Gap: Absence of a complete traceable reasoning chain from the policy evidence to final detection.

For FDO Privacy, explains based on:

The iterative process of

Policy Evidence → Ontology → SPARQL → Reasoning → Detection **Result**

is performed.

5. Misuse of semantic integration across the sections. Inability to integrate the sections semantically.

Many times, privacy information is spread throughout the policy.

There are approaches that are currently being used like retrieval or coreference resolution, but not always producing a formally connected semantic representation.

Data, purpose, recipient, retention: These types of information are frequently separated into different sections of text.

Allows them to be represented as connected ontology relationships that can be queried using SPARQL:

Data → Purpose → Recipient → Retention.

Overall Gap: There is no framework surveyed which merges all the four layers:

When extracting the knowledge from the NLP/LLM result, it is necessary to translate this into a functional ontology and then reason in SPARQL/OWL to detect overreaching functions.

FDO Privacy fills the gap by proposing a privacy-analysis framework which is unified, function-aware, and explainable.

Introduction

Due to software application proliferation, users' personal information is being collected and processed faster and more than ever before, leading to the emergence of privacy-policy analysis as a key research challenge. The privacy policies are typically natural language text where users and automated systems cannot always easily understand what information is being captured and used. There are persistent challenges in understanding, interpreting and semantically analysing privacy policy remain, as demonstrated by systematic studies on privacy-policy research [10, 11].

Initial studies were directed at the understanding of the linkage between application functions and sensitive permissions. In WHYPER, the application descriptions were matched with the Android permissions using natural language processing and semantic analysis [4]. AutoCog further analysed the semantic relatedness between application descriptions and permissions at large scale [5]. Android Permission Analysis also studied the association of the application APIs with necessary permissions in order to provide an insight of potentially overprivileged applications [6]. Later, TKPERM would be used to detect third party applications that were overprivileged across platforms using transfer learning [7]. There is recent research that has looked into the use of LLMs, like GPT-4o, to enhance the analysis of Android permissions fidelity [8].

There have also been advances in privacy-policy analysis focusing on semantic and knowledge-based methods. PolicyLint identifies inconsistencies in privacy policies through NLP-based and semantic relationships [2] and POLICHECK [3] fuses policy analysis with information on the data flow in applications to identify disclosure issues. Knowledge graphs for privacy-policy information and relations between related information across different policy sections are represented by POLIGRAPH [1]. Other more recent works, like LADFA and PrivComp-KG, integrate LLMs, retrievals and knowledge graph for automated privacy-

policy and data-flow analyses [12], [15]. Related work on privacy-risk scoring, GDPR compliance and policy completeness [14, 19, 20] exists but does not focus on the specific themes that we address.

Current solutions are mainly about identifying what data is being collected, shared, and required for compliance, however. Although minimizing unnecessary data collection is a principle of data-minimization research [9] is generally acknowledged, existing privacy-analysis systems offer limited support in determining if a collected data type is functionally necessary for the application's intended functions. Recent studies also show difficulties in generating explanations that are clear and based on the reasoning process [13] [16].

To overcome this, this work introduces a novel framework, named Functional Data Ontology (FDO) Privacy, which is a function-aware privacy-analysis framework. The framework integrates NLP/LLM-based privacy extraction, application-function modelling, RDF/OWL knowledge representation, knowledge graphs, SPARQL queries and semantic reasoning to compare the declared data with the expected data from application functions. This allows for the identification of **Functional Data Overreach** and explanations to be retrodicted to the policy evidence and semantic relationships.

Objectives:

1). Semantic Representation of Privacy Information Use natural language processing to extract unstructured privacy-policy text and the relationships among elements using Functional Data Ontology (FDO) to capture data categories, purposes, processing activities, recipients, and retention information.

2). Functional Context Modelling Capture the essential business and data components of an application and the information reasonably to be expected by an application's functions, to give a baseline functional context for the application's declared data practices to be considered within.

3). Knowledge Graph Construction and Reasoning-based Detection Capture structured privacy and/or functional knowledge into a knowledge graph, query it via SPARQL, and add a layer of reasoning to identify potential Functional Data Overreach by functional requirements, stated purpose, justification and disclosure.

4). Explainable Output for User Understanding: If you have an explanation for your output, you should share it with the user so they can understand it. Display results of the detection in an interpretable manner and correlate each instance that is flagged to the policy evidence and reasoning path, so that users can see why something was flagged.

Problem Statement:

Most privacy policies are not structured and are expressed in natural language – making privacy information hard for machines to systematically represent, connect, reason, compare and understand. Data categories, uses, processing activities, etc. can be spread throughout various sections, making it difficult to automatically analyse the relationships between them. In addition, the functionality of the application applications and declared data practices are not generally represented in a shared semantic context, which limits ability to assess if data collected is reasonably related to the functional requirements of an application. Thus, the existing text-based analysis does not offer a strong support for purpose-based detection of unnecessary and excessive data access. A technical framework is needed to convert the privacy-policy information into structured semantic knowledge, to relate it to the application functionality and anticipated data, and to allow the querying and reasoning of the knowledge-graph to explain potential Functional Data Overreach.

Methodology

The intended privacy policy analysis process outlined in the proposed FDO Privacy framework is structured so as to address the functionality of the application. This methodology uses NLP, functional data modelling, ontology based knowledge representation, semantic reasoning and functional overreach detection.

The overall methodology consists of the following stages:

1. Policy Acquisition and Preprocessing

The privacy policy of the application is fed into the system. The policy is cleaned and pre-processed to eliminate the irrelevant formatting and structure noise. The policy is then broken down into meaningful clauses/sentences for further analysis.

The original policy text is left in place, to ensure traceability between the extracted text and the source text.

2. Privacy Information Extraction

The pre-processed policy is then analysed with the NLP/LLM extraction module. The module locates pertinent privacy information and turns it into organized records.

The information extracted are:

- Data types
- Purposes
- Recipients
- Retention information
- User rights
- Supporting policy evidence

Every extracted record will include a link to the clause of the policy from which it was extracted. This enables the results of subsequent analyses to be referenced with the source text.

3. Application Function Identification

The metadata for applications is used to determine the purpose of the application. The identified functions are the functional context used in privacy analysis.

The function set is represented as:

$$\boldsymbol{F(A) = \{f_1, f_2, \ldots, f_n\}}$$

where A represents the application and f_i represents an identified application function.

4. Expected Data Mapping

Using domain knowledge and the expected-data component of the FDO model, the identified application functions are linked to the data requirements that are expected to be utilized by them. The data set to be used in the application is expected to be:

$$\boldsymbol{E(A) = \bigcup_{f_i \in F(A)} E\,(f_i)}$$

where $E(f_i)$ denotes the type(s) of data that are allowed to be passed into function f_i. This will give the baseline function to compare the data announced in the privacy policy.

5. Functional Data Ontology

The functional information and the privacy information are extracted and presented in the proposed new Functional Data Ontology.

The core concepts and relationships for functional privacy analysis are given by the ontology. The key points are:

- Application
- Function
- Data Type
- Purpose
- Recipient
- Retention
- User Right

The principal relationships include:

- performsFunction
- requiresData
- collects
- usedFor
- sharedWith
- retainedFor
- hasRightTo

The ontology provides the semantic structure required to connect application functionality with privacy information.

6. Knowledge Graph Construction

The information harvested from the application and privacy policy is used to instantiate the ontology. The result is modelled as the RDF triples and stored in an application-specific knowledge graph.

The knowledge graph incorporates:

- Application functions
- Expected data requirements
- Declared data collection
- Purposes
- Recipients
- Retention information
- User rights

This representation enables privacy information distributed across different sections of the policy to be connected through semantic relationships.

7. Semantic Reasoning

The generated RDF/OWL knowledge graph is processed using a semantic reasoning engine. Apache Jena and/or Pellet can be used to derive implicit relationships defined by the ontology.

The reasoning process generates an enriched knowledge graph:

$$\boldsymbol{G^* = \mathcal{I}(G)}$$

where G is the explicitly constructed graph and G* represents the graph after inference.

The enriched graph is subsequently used for semantic querying and functional privacy analysis.

8. SPARQL-Based Analysis

SPARQL is used to query the knowledge graph and retrieve the relationships required for privacy analysis.

The query layer supports retrieval of:

- Declared data

- Functional data requirements
- Associated purposes
- Recipients
- Retention information
- User rights
- Relevant ontology relationships
- Supporting evidence

The use of SPARQL provides a structured mechanism for analysing relationships within the knowledge graph.

9. Functional Data Overreach Detection

The declared data set extracted from the privacy policy is compared with the expected data set derived from application functions.

For each declared data type d:

$$\boldsymbol{Unexpected(d)} = \begin{cases} \mathbf{1} & \boldsymbol{d \notin E(A)} \\ \mathbf{0} & \boldsymbol{d \in E(A)} \end{cases}$$

Data that is functionally expected is classified as **Expected**.

For data that is not part of the expected set, the system performs further ontology and SPARQL-based analysis to determine whether sufficient justification exists.

The resulting classifications are:

- **Expected**
- **Justified Extension**
- **Potential Functional Data Overreach**

This classification separates functionally expected data from data requiring additional justification.

10. Risk Assessment

An optional risk-scoring component evaluates the privacy characteristics identified during analysis.

The risk assessment considers multiple dimensions, including:

- Necessity
- Transparency
- Purpose Alignment
- Sharing
- Retention
- User Control
- Consistency

The weighted risk score is calculated as:

$$\boldsymbol{Risk(A) = \sum_{k=1}^{7} w_k \, s_k(A)}$$

where w_k represents the weight of each dimension and $s_k(A)$ represents its normalized score.

Risk scoring is treated as a downstream component and does not replace the ontology-based functional analysis.

11. Explanation and Traceability

The final analysis result is accompanied by an evidence-based explanation.

For each detected issue, the system retains the relationship between:

Policy Evidence → Extracted Fact → Ontology Relationship → SPARQL Result → Reasoning → Classification

This provides traceability from the final detection back to the original privacy-policy statement and the functional relationships used during analysis.

System Architecture

The FDO Privacy system is organized into five major layers:

1. **Input Layer**
2. **Processing Layer**
3. **Semantic Knowledge Layer**
4. **Reasoning and Analysis Layer**
5. **Output Layer**

1. Input Layer

The input layer provides the information required for privacy analysis.

Components:

- Application Metadata
- Privacy Policy

Application metadata provides the functional context, while the privacy policy provides the application's declared privacy practices.

2. Processing Layer

The processing layer converts unstructured input into structured information.

Components:

- Policy Preprocessing
- NLP/LLM Extraction
- Function Identification
- Expected Data Mapping

This layer produces structured privacy facts and functional requirements for semantic representation.

3. Semantic Knowledge Layer

This layer provides the formal representation of the extracted information.

Components:

- FDO Ontology
- RDF/OWL Representation
- Application Knowledge Graph

The ontology defines the concepts and relationships, while the knowledge graph stores the application-specific instances.

4. Reasoning and Analysis Layer

This layer performs semantic analysis over the generated knowledge graph.

Components:

- OWL/RDF Reasoner
- SPARQL Query Engine
- Functional Data Overreach Detector
- Risk Assessment

The reasoning engine derives implicit relationships, SPARQL retrieves relevant knowledge, and the FDO detector compares declared data against functional requirements.

5. Output Layer

The output layer presents the results of the analysis.

Outputs:

- Data classification
- Functional Data Overreach findings
- Supporting policy evidence
- Reasoning path
- Risk score
- Explanation

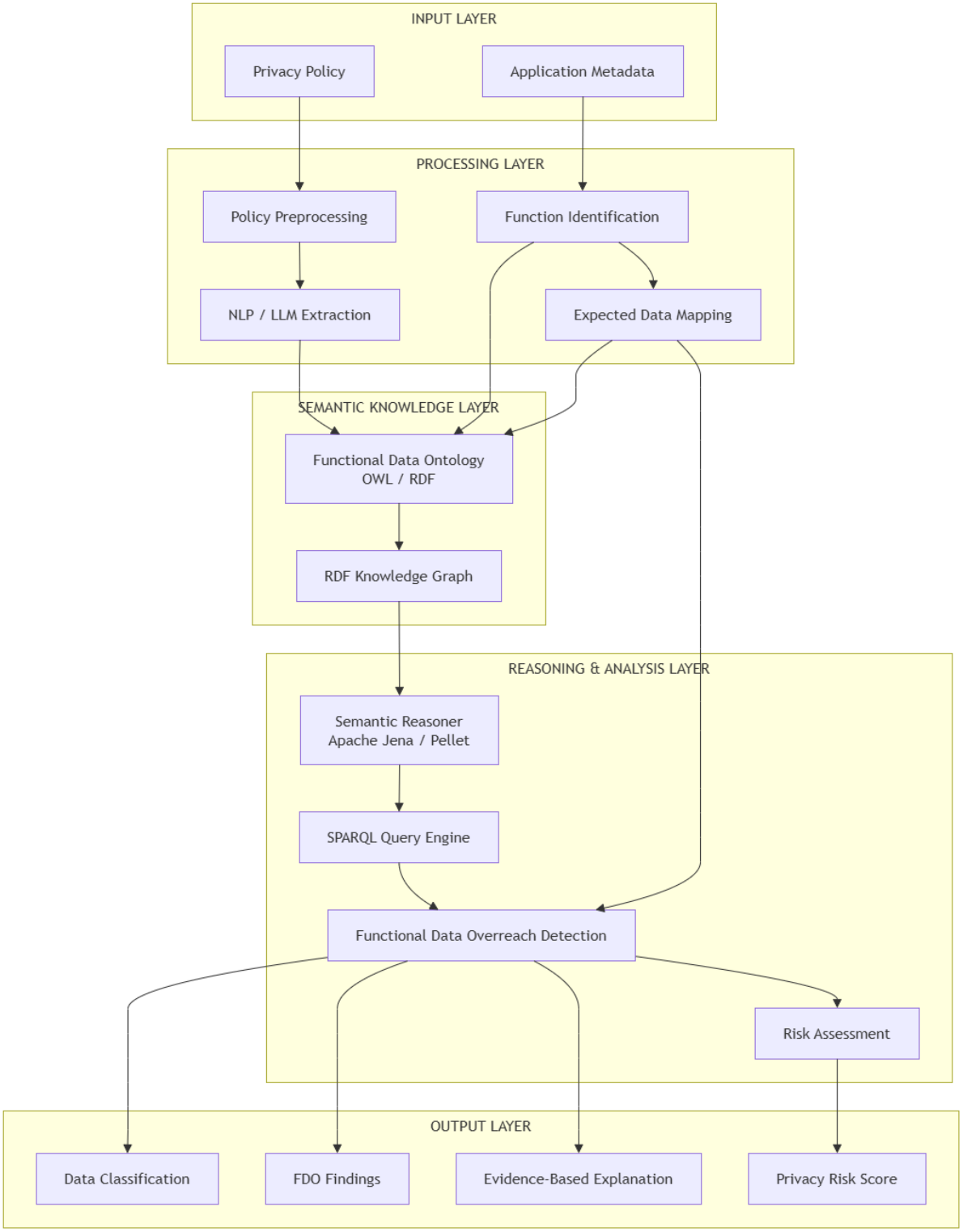
Modules and Their Functionality

Module	Functionality
Application Input Module	Collects and validates application metadata required for functional analysis.
Policy Input Module	Accepts the privacy policy for analysis.
Policy Preprocessing Module	Cleans and segments the privacy policy into analysable units.
NLP/LLM Extraction Module	Extracts privacy entities, relationships, and supporting evidence from policy text.
Function Identification Module	Identifies the functional capabilities of the application.
Expected Data Mapping Module	Associates application functions with their expected data requirements.
FDO Ontology Module	Defines the concepts and semantic relationships used by the framework.
RDF Knowledge Graph Module	Converts extracted information into RDF triples and constructs the application knowledge graph.
Semantic Reasoning Module	Applies ontology-based reasoning to derive implicit relationships.
SPARQL Query Module	Retrieves relevant privacy and functional relationships from the knowledge graph.
FDO Detection Module	Compares declared data with expected data and identifies potential Functional Data Overreach.
Risk Assessment Module	Calculates the optional overall privacy-risk score.
Explanation Module	Generates traceable explanations using extracted evidence and semantic relationships.
Result Module	Presents classifications, findings, evidence, explanations, and risk information.

System Architecture Diagram

The overall architecture follows the sequence:

Input → Extraction → Functional Modelling → Ontology → Knowledge Graph → Reasoning → Analysis → Output



Architecture Flow

The architecture can therefore be understood as four major transformations:

1. Unstructured Information

Privacy policy and application metadata are provided to the system.

↓

2. Structured Information

NLP/LLM processing identifies privacy facts, while functional analysis identifies application functions and expected data.

↓

3. Semantic Representation

The extracted information is represented using FDO, RDF/OWL, and the application knowledge graph.

↓

4. Semantic Decision

Reasoning and SPARQL analysis support the comparison between declared and expected data, leading to FDO detection, risk assessment, and evidence-based explanations.

References

[1] H. Cui et al., “POLIGRAPH: Automated Privacy Policy Analysis Using Knowledge Graphs,” 2023.

[2] B. Andow et al., “PolicyLint: Investigating Internal Privacy Policy Contradictions on Google Play,” 2019.

[3] B. Andow et al., “Actions Speak Louder than Words: Entity-Sensitive Privacy Policy and Data Flow Analysis with POLICHECK,” 2020.

[4] R. Pandita et al., “WHYPER: Towards Automating Risk Assessment of Mobile Applications,” 2013.

[5] Z. Qu et al., “AutoCog: Measuring the Description-to-Permission Fidelity in Android Applications,” 2014.

[6] A. P. Felt, E. Chin, S. Hanna, D. Song, and D. Wagner, “Android Permissions Demystified,” 2011.

[7] F. H. Shezan, K. Cheng, Z. Zhang, Y. Cao, and Y. Tian, “TKPERM: Cross-platform Permission Knowledge Transfer to Detect Overprivileged Third-party Applications,” 2020.

[8] Y. Tamrakar, R. Banerjee, E. Myers, L. De Carli, and I. Ray, “Harnessing Language Models to Analyze Android App Permission Fidelity,” 2025.

[9] A. J. Biega, P. Potash, H. Daumé III, F. Diaz, and M. Finck, “Operationalizing the Legal Principle of Data Minimization for Personalization,” 2020.

[10] Y. Javed and A. Sajid, “A Systematic Review of Privacy Policy Literature,” 2024.

[11] J. M. Del Alamo, D. S. Guaman, B. García, and A. Diez, “A Systematic Mapping Study on Automated Analysis of Privacy Policies,” 2022.

[12] H. Yuan, N. Matyunin, A. Raza, and S. Li, “LADFA: A Framework of Using Large Language Models and Retrieval-Augmented Generation for Personal Data Flow Analysis in Privacy Policies,” 2025.

[13] V. Freiberger, A. Fleig, and E. Buchmann, “Explainable AI in Usable Privacy and Security: Challenges and Opportunities,” 2025.

[14] N. Kim, H. Oh, and J. K. Choi, “A Privacy Scoring Framework: Automation of Privacy Compliance and Risk Evaluation with Standard Indicators,” 2023.

[15] L. Garza, L. Elluri, A. Kotal, A. Piplai, D. Gupta, and A. Joshi, “PrivComp-KG: Leveraging Knowledge Graph and Large Language Models for Privacy Policy Compliance Verification,” 2024.

[16] Y. Chen, P. Tang, W. Qiu, and S. Li, “Using LLMs for Automated Privacy Policy Analysis: Prompt Engineering, Fine-Tuning and Explainability,” 2025.

[17] J. Chung, R. Ko, W. Yoo, M. Onizuka, S. Kim, T.-W. Kim, and W.-Y. Shin, “GraphCompliance: Aligning Policy and Context Graphs for LLM-Based Regulatory Compliance,” 2025.

[18] R. Zhao, V. Melnychuk, J. Zhao, J. Wright, and N. Shadbolt, “Let’s Measure the Elephant in the Room: Facilitating Personalized Automated Analysis of Privacy Policies at Scale,” 2025.

[19] Z. S. Li, C. Werner, N. Ernst, and D. Damian, “GDPR Compliance in the Context of Continuous Integration,” 2020.

[20] O. A. Cejas, S. Abualhaija, and L. C. Briand, “CompAi: A Tool for GDPR Completeness Checking of Privacy Policies Using Artificial Intelligence,” 2024.